

HỌC VIỆN NGÂN HÀNG
KHOA CÔNG NGHỆ THÔNG TIN & KINH TẾ SỐ



CHƯƠNG II

CÁC LỖ HỔNG BẢO MẬT & ĐIỂM YẾU HỆ THỐNG

Nội dung

2.1

Tổng quan về bảo mật và điểm yếu

2.2

Các dạng lỗ hổng trong HDH và U'D

2.3

Quản lý, khắc phục và tăng cường

2.4

Một số công cụ rà quét

2.1. Tổng quan về lỗ hổng và điểm yếu

- ❖ **Mối đe dọa:**
- ❖ **Các điểm yếu:**
- ❖ **Lỗ hổng bảo mật:**
- ❖ **Tấn công:**

$$\text{Tấn công} = \text{Mối đe dọa} + \text{Lỗ hổng}$$

2.2. Các dạng lỗ hổng trong HDH và UD

2.2.1 Các dạng mối đe dọa

- ❖ Phần mềm độc hại:
- ❖ Kẻ tấn công ở bên trong
- ❖ Kẻ tấn công ở bên ngoài:
- ❖ Hư hỏng phần cứng và phần mềm
- ❖ Mất trộm các thiết bị:
- ❖ Tai họa thiên nhiên
- ❖ Gián điệp công nghệ:
- ❖ Khủng bố phá hoại

2.2. Các dạng lỗ hổng trong HDH và UD

2.2.2 Các loại tấn công

❖ Theo mục đích thực hiện

- ❑ **Giả mạo:** Đánh lừa người dùng thông thường
- ❑ **Chặn bắt:** Liên quan đến việc nghe lén trên đường truyền và chuyển hướng thông tin để sử dụng trái phép
- ❑ **Ngắt quãng:** làm chậm kênh đường truyền hoặc quá tải hệ thống nhằm ngăn cản việc truy cập dịch vụ
- ❑ **Sửa đổi:** Sửa đổi thông tin trên đường truyền hoặc sửa đổi dữ liệu file

2.2. Các dạng lỗ hổng trong HDH và UD

2.2.2 Các loại tấn công

❖ Theo hình thức thực hiện

- ❑ Tấn công chủ động:

- ❑ Tấn công thụ động:

2.2. Các dạng lỗi hỏng trong HDH và UD

2.2.3 Các dạng lỗi hỏng

❖ Trong hệ điều hành

- ❑ Lỗi hỏng xác thực và quản lý định danh: Mật khẩu; cơ chế xác thực lỗi thời; tài khoản không còn sử dụng
- ❑ Lỗi hỏng phân quyền và kiểm soát truy cập: Sai cấu hình quyền file, thư mục, registry
- ❑ Lỗi hỏng kernel, driver và hệ thống lõi
- ❑ Lỗi hỏng quản lý bộ nhớ

2.2. Các dạng lỗ hổng trong HDH và UD

2.2.3 Các dạng lỗ hổng

❖ Trong hệ điều hành

- ❑ Lỗ hổng dịch vụ hệ thống & network stack
- ❑ Lỗ hổng cấu hình HDH
- ❑ Lỗ hổng cập nhật, vá lỗi
- ❑ Lỗ hổng ghi log và giám sát

2.2. Các dạng lỗ hổng trong HDH và UD

2.2.3 Các dạng lỗ hổng

❖ Trong Ứng dụng

- ❑ Lỗ hổng xác thực
- ❑ Lỗ hổng phân quyền
- ❑ Lỗ hổng xử lý đầu vào/đầu ra
- ❑ Lỗ hổng quản lý phiên
- ❑ Lỗ hổng xử lý file
- ❑ Lỗ hổng mã hóa và bảo vệ dữ liệu
- ❑ Lỗ hổng cấu hình ứng dụng
- ❑ Lỗ hổng thư viện và bên thứ ba

2.3. Quản lý, khắc phục và tăng cường

2.3.1 Nguyên tắc tổng thể

❖ Quản lý theo vòng đời rủi ro

❑ Nhận diện -> Đánh giá -> Xử lý -> Giám sát -> Cải tiến

❑ Áp dụng Risk-base Security

❖ Phòng thủ nhiều lớp

❑ Con người – Quy trình – Công nghệ

❑ Không phụ thuộc một biện pháp đơn lẻ

2.3. Quản lý, khắc phục và tăng cường

2.3.2 Quản lý khắc phục tăng cường theo nhóm lỗ hổng

❖ Xác thực & quản lý định danh (IAM):

- ❑ Xây dựng chính sách IAM tập trung
- ❑ Chuẩn hóa quy trình cấp – thu hồi – thay đổi quyền
- ❑ Phân tách tài khoản người dùng và quản trị
- ❑ Chính sách mật khẩu mạnh
- ❑ Vô hiệu hóa tài khoản không sử dụng, loại bỏ tài khoản mặc định

2.3. Quản lý, khắc phục và tăng cường

2.3.2 Quản lý khắc phục tăng cường theo nhóm lỗ hổng

❖ Phân quyền & kiểm soát truy cập:

- ❑ Rà soát quyền định kỳ, loại bỏ quyền dư thừa
- ❑ Không chạy dịch vụ với quyền Root/Admin
- ❑ Kiểm soát truy cập ở cả frontend và backend

2.3. Quản lý, khắc phục và tăng cường

2.3.2 Quản lý khắc phục tăng cường theo nhóm lỗi hỏng

❖ Lỗi hỏng Kernel, bộ nhớ, thực thi mã:

- ❑ Kiểm soát driver, kernel module
- ❑ Vá lỗi kịp thời
- ❑ Chặn unsigned driver

2.3. Quản lý, khắc phục và tăng cường

2.3.2 Quản lý khắc phục tăng cường theo nhóm lỗ hổng

❖ Cấu hình hệ điều hành & dịch vụ:

- ☐ Quản lý cấu hình tập trung
- ☐ Tắt dịch vụ/ cổng không cần thiết
- ☐ Vô hiệu giao thức yếu (Telnet)
- ☐ Cấu hình firewall nội bộ

2.3. Quản lý, khắc phục và tăng cường

2.3.2 Quản lý khắc phục tăng cường theo nhóm lỗi hỏng

❖ Quản lý vá lỗi & cập nhật:

- ❑ Phân loại dữ liệu theo mức độ quan trọng
- ❑ Kiểm tra tương thích trước khi vá

2.3. Quản lý, khắc phục và tăng cường

2.3.2 Quản lý khắc phục tăng cường theo nhóm lỗ hổng

❖ Mã hóa & bảo vệ dữ liệu:

- ❑ Phân loại dữ liệu

- ❑ Mã hóa dữ liệu nhạy cảm

- ❑ Loại bỏ các thông tin bí mật (hardcoded secrets)

2.3. Quản lý, khắc phục và tăng cường

2.3.2 Quản lý khắc phục tăng cường theo nhóm lỗ hổng

❖ Logging, giám sát:

- ❑ Chuẩn hóa log

- ❑ Ghi log đầy đủ: danh tính, quyền được phép làm, hoạt động quản trị, các giao dịch thực hiện

- ❑ Bảo vệ log khỏi chỉnh sửa

2.3. Quản lý, khắc phục và tăng cường

2.3.2 Quản lý khắc phục tăng cường theo nhóm lỗi hỏng

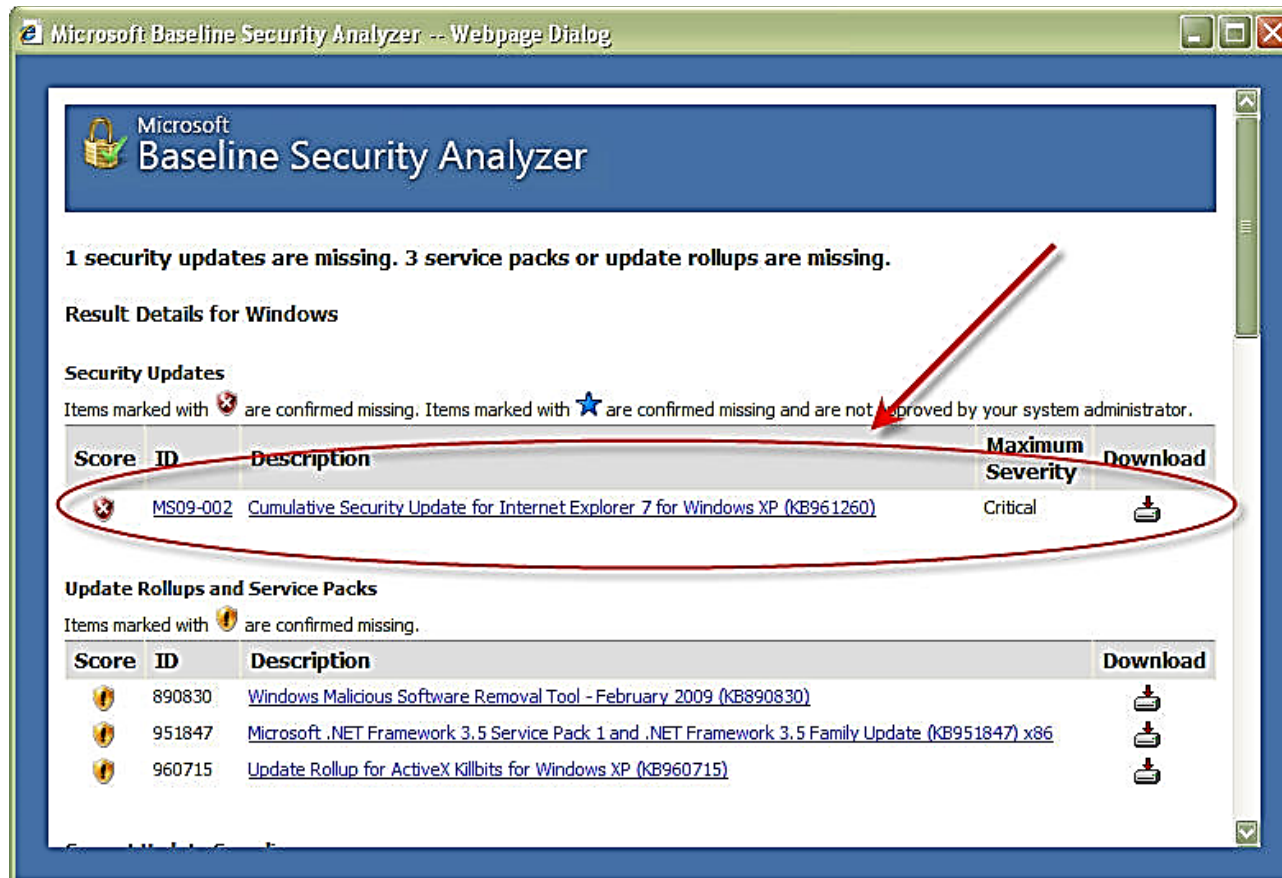
❖ Bên thứ ba & chuỗi cung ứng:

- ❑ Đánh giá mức độ an toàn của nhà cung cấp
- ❑ Vá thư viện lỗi thời
- ❑ Kiểm soát quyền truy cập của đối tác

2.4. Một số công cụ rà quét

2.4.1 Công cụ rà quét lỗ hổng, điểm yếu hệ thống

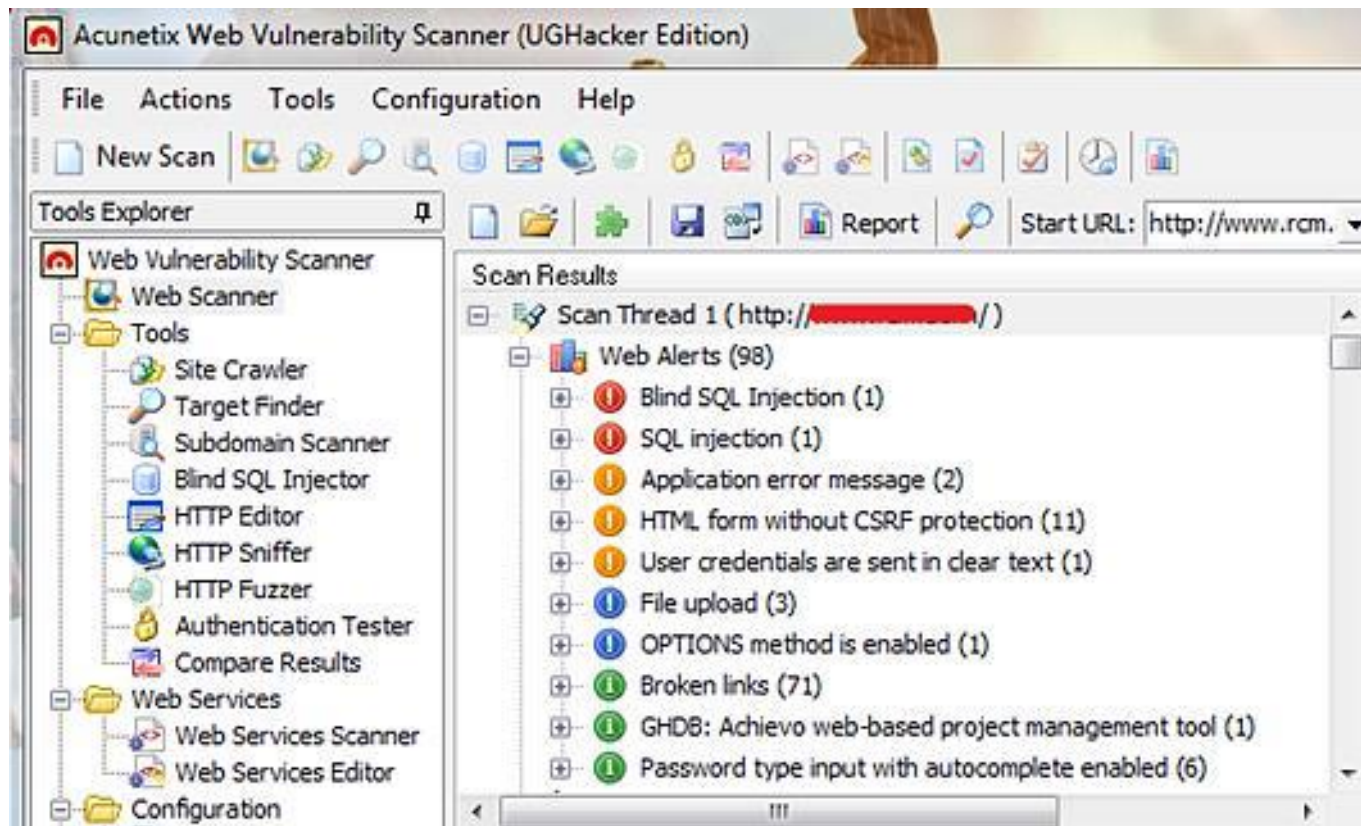
❖ Công cụ rà quét lỗ hổng bảo mật: Microsoft Baseline Security Analyzer



2.4. Một số công cụ rà quét

2.4.1 Công cụ rà quét lỗ hổng, điểm yếu hệ thống

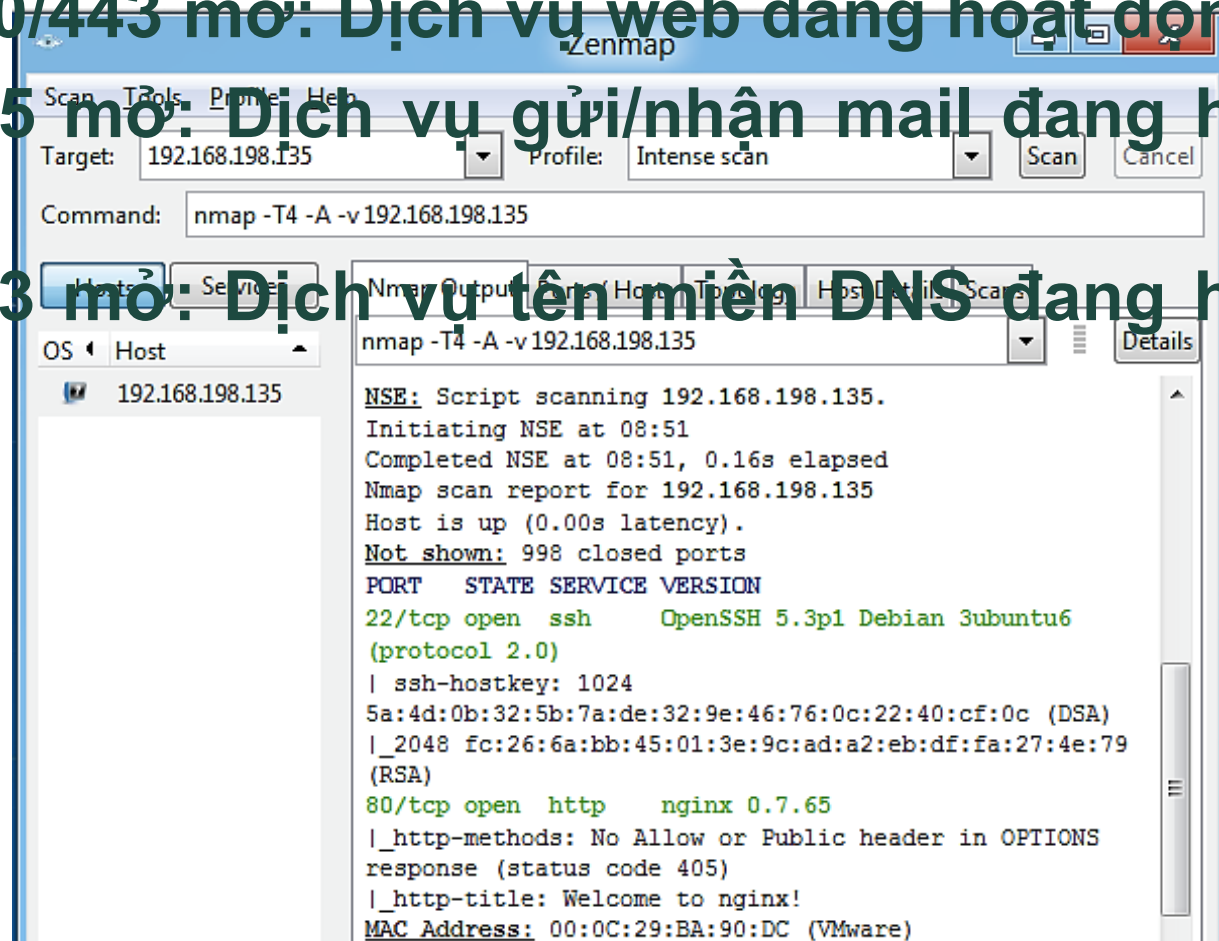
❖ Công cụ rà quét lỗ hổng ứng dụng Web: Acunetix Web Vulnerability Scanner



2.4. Một số công cụ rà quét

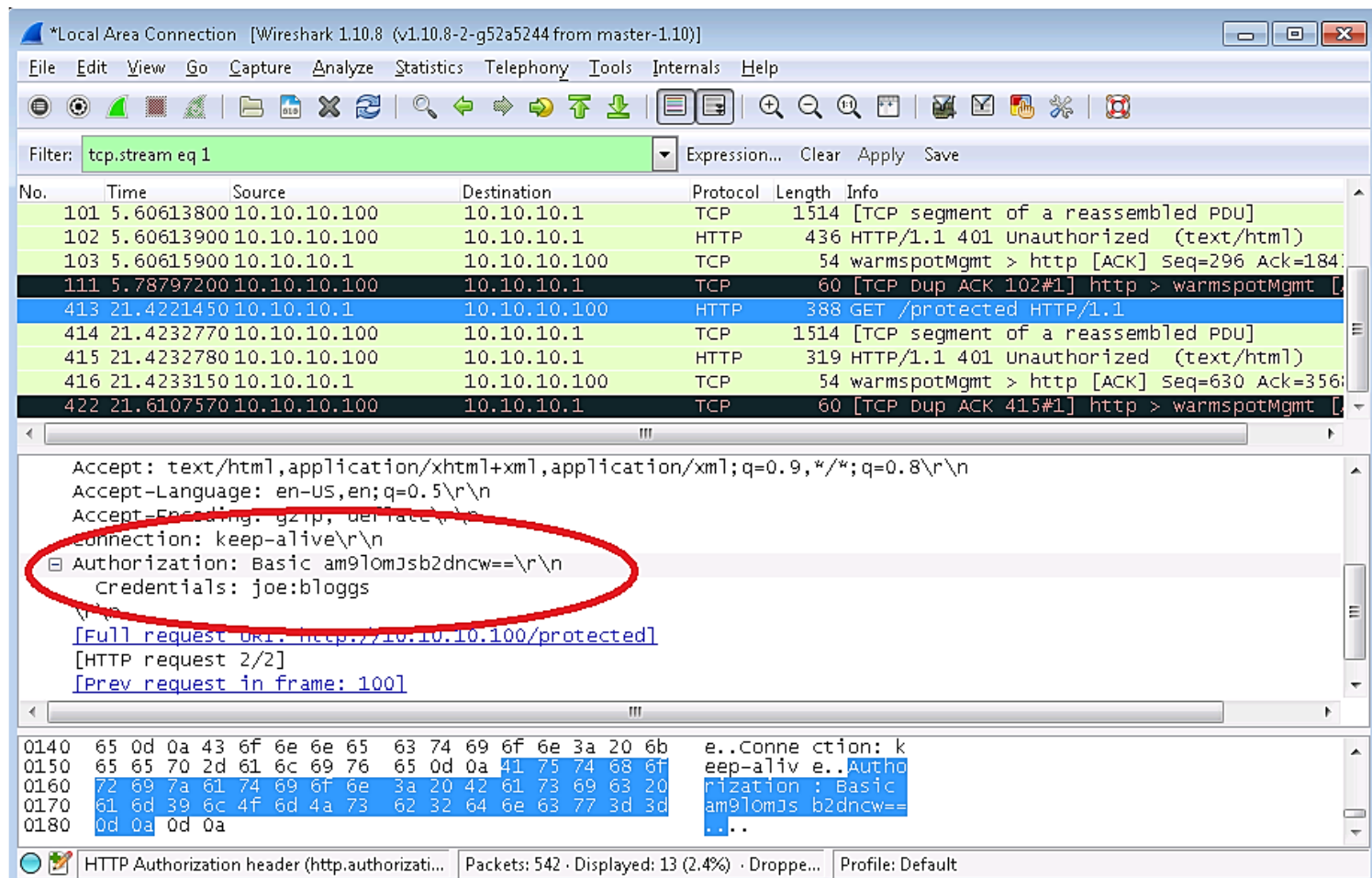
2.4.2 Công cụ quét cổng dịch vụ

- ❖ Cổng 80/443 mở: Dịch vụ web đang hoạt động
- ❖ Cổng 25 mở: Dịch vụ gửi/nhận mail đang hoạt động
- ❖ Cổng 53 mở: Dịch vụ tên miền DNS đang hoạt động



2.4. Một số công cụ rà quét

2.4.3 Công cụ nghe trộm



Công cụ Wireshark

2.4. Một số công cụ rà quét

2.4.3 Công cụ ghi bàn phím



Modul Keylogger



Thank You !